

Informe de Seguridad: Análisis Forense y Hardening de Servidor Debian

Revisión Técnica de las Fases 1, 2 y 3

ESTADO INICIAL

Compromiso Total del Sistema /
Acceso Root No Autorizado

ESTADO FINAL

Recuperación y Fortalecimiento
bajo normativa SGSI

RESUMEN DEL INCIDENTE: CONTEXTO INICIAL

SITUACIÓN:

Se ha confirmado un compromiso total del sistema tras detectar acceso no autorizado a la cuenta de superusuario (root).

VECTORES DE ENTRADA:

Configuraciones débiles en servicios críticos expuestos:

- SSH (Puerto 22)
- FTP (Puerto 21)
- Apache (Puerto 80)

PROTOCOLO DE RESPUESTA



Preservación de Pruebas: Copia forense bit-a-bit garantizando la cadena de custodia antes del análisis.

FASE 1: ANÁLISIS FORENSE - DETECCIÓN DEL INTRUSO

Evidencia #01: Logs de Systemd (journalctl)

- **Confirmación:** Acceso exitoso registrado como 'Accepted password for root'.
- **Origen:** IP 192.168.0.134
- **Puerto:** 45623 (Atípico)
- **Causa Raíz:** Directiva 'PermitRootLogin Yes' habilitada en SSH.

EXHIBIT 02: SYSTEM LOGS - SSH ACCESS

```
debian@debian:~$ sudo journalctl -u ssh | grep "Failed password"
debian@debian:~$ sudo journalctl -u ssh | grep "Accepted"
Oct 08 17:40:59 debian sshd[1650]: Accepted password for root from 192.168.0.134
port 45623 ssh2
debian@debian:~$
```


FASE 1: INTEGRIDAD DEL SISTEMA Y PERSISTENCIA

EXHIBIT 03: SYSTEM CRASH LOGS

File Edit View Search Terminal Help

debian@debian:~\$ last

debian	tty7	:0	Fri Jan 9 10:09	still logged in
reboot	system boot	6.1.0-25-amd64	Fri Jan 9 10:09	still running
debian	tty7	:0	Tue Oct 8 17:28	- crash (457+17:40)
reboot	system boot	6.1.0-25-amd64	Tue Oct 8 17:28	- still running
debian	tty7	:0	Tue Oct 8 16:48	- crash (00:40)
reboot	system boot	6.1.0-25-amd64	Tue Oct 8 16:48	- still running
debian	tty7	:0	Tue Oct 8 16:44	- crash (00:03)
reboot	system boot	6.1.0-25-amd64	Tue Oct 8 16:43	still running
debian	tty7	:0	Mon Sep 30 15:13	- crash (8+01:29)
reboot	system boot	6.1.0-25-amd64	Mon Sep 30 15:09	still running
debian	tty7	:0	Mon Sep 30 09:49	- 12:27 (02:38)
reboot	system boot	6.1.0-23-amd64	Mon Sep 30 09:49	- 12:28 (02:39)
debian	tty7	:0	Sat Sep 28 16:40	- 12:28 (1+17:08)
reboot	system boot	6.1.0-23-amd64	Sat Sep 28 16:39	- 12:28 (1+19:48)
debian	tty7	:0	Wed Jul 31 16:45	- 18:18 (01:33)
reboot	system boot	6.1.0-23-amd64	Wed Jul 31 16:45	- 18:19 (01:34)
debian	tty7	:0	Wed Jul 31 16:04	- 16:44 (00:39)
reboot	system boot	6.1.0-23-amd64	Wed Jul 31 16:04	- 16:44 (00:40)
debian	tty7	:0	Wed Jul 31 15:57	- 15:59 (00:01)
reboot	system boot	6.1.0-23-amd64	Wed Jul 31 15:56	- 15:59 (00:02)

wtmp begins Wed Jul 31 15:56:58 2024

debian@debian:~\$

Análisis de Estabilidad

- El comando 'last' revela múltiples 'crashes' coincidiendo con la conexión de la IP atacante (192.168.0.134), indicando inestabilidad severa.

EXHIBIT 04: ARTEFACT SEARCH RESULTS

utmp begins Wed Jul 31 15:56:58 2024

root@debian:~\$ sudo find / -name '* 2024-10-08 17:44:00' ! -name '* 2024-10-08 18:05:00' -ls >/dev/null

[sode] passed for de0lan:

```
123456 1179674 4 -rw-r--r-- 1 debian debian 3638 Oct 8 2024 /home/debian/.xsession-errors.old
1053 0 -r--r--r-- 1 root root 8 Oct 8 2024 /var/lib/systemd/timers/Stamp-fstrim.timer
1702558 28 -r--r--r-- 1 root root 26934 Oct 8 2024 /var/log/Xorg.0.log.old
218 8136 -r--r--r-- 1 root systemd-journal 8388668 Oct 8 2024 /var/log/journal/4166de202274fdaa4904117748aaa
ff/sysecn/0006471Seal00060f-4e0e30271e0e0c11.journal-
Seal00060f-4e0e30271e0e0c11.journal-
```

Búsqueda de Artefactos (Persistencia)

- Auditoría de archivos modificados entre 17:40 - 18:05.
- **Resultado:** No se detectaron nuevos ejecutables maliciosos en el disco. **El ataque pudo residir en memoria o limitarse a cambios de configuración.**

FASE 2: ANÁLISIS DE VULNERABILIDADES - SUPERFICIE DE ATAQUE

Escaneo de Red (Nmap)

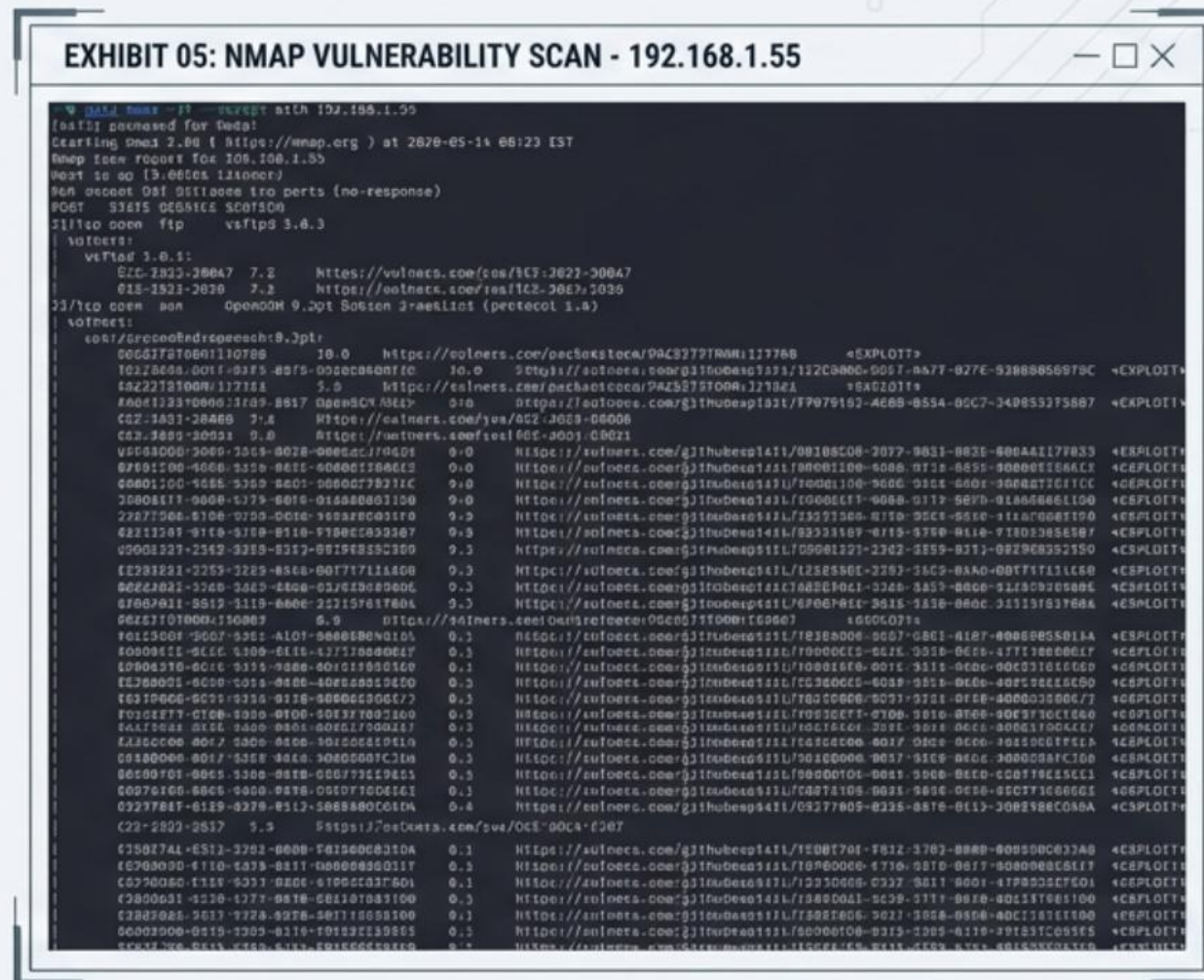
Servicios Críticos Expuestos:

- **21/tcp (FTP):** vsftpd 3.0.3 (**Obsoleto/Inseguro**)
- **22/tcp (SSH):** OpenSSH 9.2p1
- **80/tcp (HTTP):** Apache 2.4.62

Servicios Innecesarios:

- Puerto 25 (SMTP)
- Puerto 631 (IPP - Impresión)

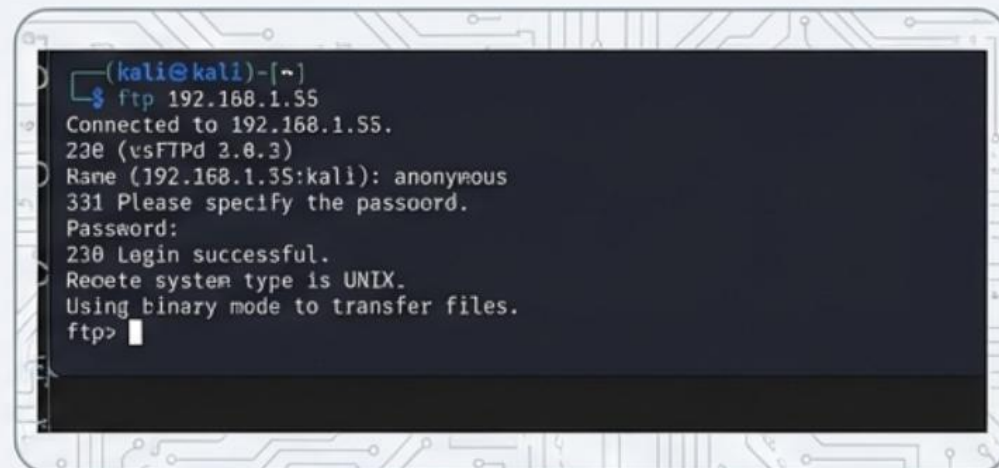
Nota: Estos servicios aumentan la superficie de ataque sin justificación operativa.



Fase 2: Vulnerabilidades Críticas en Infraestructura

FTP Vulnerability

FTP (vsftpd 3.0.3): Acceso 'anonymous' habilitado. CVE-2021-30047 (DoS/RCE).

A terminal window with a dark background and light blue text. The prompt is '(kali@kali)-[~]'. The user enters '\$ ftp 192.168.1.55'. The output shows a successful connection to 192.168.1.55 using vsFTPd 3.0.3. The user is prompted for a password and enters 'anonymous'. The server responds with '230 Login successful.' and 'Recete system type is UNIX. Using binary mode to transfer files.' The prompt returns to 'ftp>'.

```
(kali@kali)-[~]  
$ ftp 192.168.1.55  
Connected to 192.168.1.55.  
230 (vsFTPd 3.0.3)  
Name (192.168.1.55:kali): anonymous  
331 Please specify the password.  
Password:  
230 Login successful.  
Recete system type is UNIX.  
Using binary mode to transfer files.  
ftp>
```

EXHIBIT 06: ANONYMOUS FTP LOGIN SUCCESS

SSH Vulnerability

SSH (OpenSSH 9.2p1): Vulnerable a regreSSHion (CVE-2024-6387).

Impacto Crítico: Permite ejecución remota de código (RCE) como root sin autenticación (Race Condition).



EXHIBIT 07: CRITICAL VULNERABILITY ALERT - REGRESSHION

Fase 2: Exposición de Datos en Capa de Aplicación

```
debian@debian:~$ ls -l /var/www/html/wp-config.php
-rwxrwxrwx 1 www-data www-data 3017 Sep 30 2024 /var/www/html/wp-config.php
```

EXHIBIT 08: INSECURE PERMISSIONS ON wp-config.php

1. Permisos Inseguros (755)

El archivo `wp-config.php` es legible y escribible por cualquier usuario del sistema.

```
debian@debian:~$ cat /var/www/html/wp-config.php | grep -E 'DB_USER|DB_PASSWORD'
define( 'DB_USER', 'wordpressuser' );
define( 'DB_PASSWORD', '123456' );
```

EXHIBIT 09: EXPOSED DATABASE CREDENTIALS

2. Credenciales en Texto Plano

Usuario: `wordpressuser` / Password: `123456`. Acceso directo a la base de datos MariaDB expuesto debido a contraseñas débiles y permisos laxos.

Medidas de Corrección Inmediata (Hardening)

EXHIBIT 10: SECURE SSH CONFIGURATION (PermitRootLogin)

```
File Edit View Search Terminal Help
GNU nano 7.2 /etc/ssh/sshd_config *
#
PermitRootLogin no
```

EXHIBIT 10: SECURE SSH CONFIGURATION (PermitRootLogin)

EXHIBIT 11: SECURE FTP CONFIGURATION (Anonymous Disabled)

```
#
# Allow anonymous FTP? (Disabled by default).
anonymous_enable=NO
#
# Uncomment this to allow local users to log in.
```

EXHIBIT 11: SECURE FTP CONFIGURATION (Anonymous Disabled)

Actions Executed

- ✓ **SSH:** Cambio de directiva a `PermitRootLogin no`. Parcheo de OpenSSH.
- ✓ **FTP:** Deshabilitación de usuario anónimo (`anonymous_enable=NO`).
- ✓ **Archivos:** `chmod 600` aplicado a `wp-config.php` (Solo lectura para owner).
- ✓ **Sistema:** Actualización completa (`apt update && upgrade`) para mitigar CVEs.

Fase 3: Plan de Gestión y Seguridad Futura (SGSI)

Control de Acceso

Prohibición estricta de root en SSH.
Eliminación de cuentas anónimas.
Transición obligatoria a SFTP/HTTPS.

Detección y Monitoreo

Revisión continua de journalctl para identificar fuerza bruta.
Auditoría periódica de bash_history.

Protección de Datos (DLP)

Cifrado de bases de datos MariaDB.
Copias de seguridad offline e **inmutables**.

Marco Normativo

Alineación de controles técnicos con el estándar **ISO 27001**.

Conclusión y Estado Final

Resumen de Ejecución del Proyecto

Fase 1 (Contención):

- ✓ Intrusión detectada y aislada. Evidencia preservada correctamente.

Fase 2 (Análisis):

- ✓ Vulnerabilidades críticas (regreSSHion, FTP Anónimo, Permisos Web) identificadas y mitigadas.

Fase 3 (Gobernanza):

- ✓ Políticas de seguridad activas.

El servidor ha transicionado de un estado de COMPROMISO TOTAL a un entorno de RECUPERACIÓN y FORTALECIMIENTO.